

OpenID Financial-grade API (FAPI 1.0 Advanced Security Profile)

Cryptographic Token Constraints, Sender-Constrained Artifacts & Client Assertion Protocols

Standard Setter:	OpenID Foundation Financial-grade API Working Group
Specification ID:	OIDF-FAPI-1.0-ADV
Classification:	High-Assurance Identity & Authorization Standard
Verification:	Integrated in Ariya Sarrafzadeh Production Architecture

1. Purpose & Threat Model

FAPI 1.0 Advanced provides JSON/REST security mechanisms capable of defending financial services APIs against network eavesdropping, token injection, token replay, and authorization code interception.

2. Sender-Constrained Tokens (mTLS & DPoP)

Access tokens are bound cryptographically to the client's TLS certificate (RFC 8705) or Demonstrating Proof-of-Possession key (DPoP RFC 9449). A stolen bearer token cannot be replayed from unauthorized infrastructure.

3. Pushed Authorization Requests (PAR) & JARM

Authorization parameters are transmitted via direct back-channel HTTP POST (RFC 9126 PAR) rather than front-channel browser redirects, preventing parameter tampering. Responses are signed with JWS via JARM (JWT Secured Authorization Response Mode).

4. Cryptographic Nonce & Token Lifetime Management

Strict entropy requirements for authorization codes, state, and nonces. Access tokens carry short TTLs (typically 300 seconds), backed by rotating refresh tokens.

Systems Verification Notice: This authoritative specification establishes the invariant compliance baseline for production fintech switches, settlement reconciliation engines, and double-entry ledger implementations documented across the portfolio.